

練習 28：客製 Table Maintenance 的權限防護與並行控制

授課順序：接在練習 27 (Lock Object) 之後。講義見 [lec28](#)。

學習目標

- 理解 SM30 原生權限檢查 (`S_TABU_DIS/S_TABU_NAM`) 只到表格層級，業務維度要自己包 Wrapper
- 會在 SU21 建立自訂權限物件 (`ACTVT` + 業務欄位)，並知道 `AUTHORITY-CHECK` 怎麼呼叫
- 理解 Lock Object 的鎖定範圍不必等於表格主鍵，要對應「使用者實際爭搶的資源邊界」
- 會用 `VIEW_MAINTENANCE_CALL` 從程式呼叫標準 Table Maintenance，並用 `dba_sellist` 依欄位篩選只顯示授權範圍內的資料
- 理解「T-code 要指給 Wrapper 程式，不能指給裸的 SM30」這個設計為什麼重要
- 會用 `SELECTION-SCREEN FUNCTION KEY` 在選取畫面加自訂按鈕，並理解「直接 `CALL TRANSACTION 'SM30'`」跟「透過 Wrapper 正規呼叫」在保護程度上的差別

事前準備

物件建在套件 `$TMP`。沿用練習 21 學過的 Z 表 + 外鍵技巧，這次外鍵指向標準表 `T001W` (工廠主檔，呼應練習 25「Check Table 指向標準表」的手法)。

第一部分：DDIC (已由 Claude 建立並啟用，可直接對照)

- Domain/DE `ZTR28_PCODE` (CHAR 10，參數代碼)、`ZTR28_PARVAL` (CHAR 40，參數值) ——`PARTXT` (說明文字) 重用標準 DE `TEXT40`，不用另外自建 (呼應練習 25「能重用標準就不要自己蓋」的判斷)
- 表 `ZTR28_WPARAM`：

欄位	Key	型別來源	說明
MANDT	✓	Data Element <code>MANDT</code>	client
WERKS	✓	Data Element <code>WERKS_D</code> ，外鍵指向標準表 <code>T001W</code>	工廠
PARAM	✓	Data Element <code>ZTR28_PCODE</code>	參數代碼
PARVAL		Data Element <code>ZTR28_PARVAL</code>	參數值
PARTXT		標準 Data Element <code>TEXT40</code>	參數說明
UPDUSER		Data Element <code>SYUNAME</code>	異動者
UPDDATE		Data Element <code>SYDATUM</code>	異動日

外鍵 `WERKS` 的 Check Table 是標準表 `T001W` (不是自建表)，Cardinality `[0..*,1]`，`screenCheck`：`true`。

第二部分：SU21 建立自訂權限物件 (需使用者手動建立，ADT 沒有建立 API)

1. **SU21** → Object Class 選 **BC_A** (Basis: Administration ; ⚠ **BC** 本身不是合法的 Class 代碼，只是分類字首，實際要選 **BC_A/BC_C/BC_Z** 這種細分類，存檔時如果選了不存在的 Class 會報紅字錯誤「Object class ... does not exist」) → Create Authorization Object
2. 物件名稱 **ZTR28_WERK** (權限物件名稱上限 10 碼，**ZTR28_WERKS** 有 11 碼會超過，要縮寫掉一個字母)，Short Text 自訂
3. Authorization Fields： **ACTVT** (標準欄位)、**WERKS** (本題業務欄位，型別參考 Data Element **WERKS_D**)
4. 存檔、Activate (存檔時如果看到黃色警告「Permissible activities not maintained for field ACTVT」可以忽略，不影響後續使用)
5. 這一步只是定義「有哪些欄位可以管控」，真正要讓某個使用者擁有權限，還要走完下面的 **PFCG** 流程——缺這一步的話，任何人 **AUTHORITY-CHECK** 都會失敗 (**sy-subrc <> 0**)，程式邏輯本身不受影響

⚠ **ZTR28_WERK** (權限物件，無 **S**) 跟 **EZTR28_WERKS** (**Lock Object**，有 **S**、**E** 開頭) 拼法相近但不同，操作時注意看清楚。

第二點五部分：PFCG 角色維護 (需使用者手動建立，權限真正生效的關鍵，詳細操作見講義第 3.1 節)

1. **PFCG** → Role 欄位輸入 **ZTR28_MAINT_ROLE** → **Single Role** → Create
2. Description 頁籤填說明 → 存檔
3. Menu 頁籤 → Transaction → 輸入 **ZTR28_MAINT** → Enter
4. Authorizations 頁籤 → 鉛筆圖示 Change Authorization Data → **Manually** 按鈕輸入 **ZTR28_WERK** → Enter
5. 展開 **ZTR28_WERK** 節點： **ACTVT** 填 **02**、**WERKS** 填 **1011**；確認 **S_TCODE** 底下的 **TCD** 有 **ZTR28_MAINT**
6. 齒輪圖示 **Generate** 產生 Profile
7. User 頁籤輸入自己的使用者代號 → **User Comparison** → Complete Comparison
8. 存檔
9. 登出重新登入 (或開新 Session) 驗證：SU53 可查上一次權限失敗的細節

第三部分：SE11 建立 Lock Object (需使用者手動建立)

1. SE11 → Lock Object → **EZTR28_WERKS** (系統強制要求 **E** 開頭，不是命名慣例；⚠ 注意別跟第二部分的權限物件 **ZTR28_WERK** 搞混，兩者拼法相近但不同) → Create
2. Primary Table： **ZTR28_WPARAM**
3. Lock Parameters：只勾 **MANDT**、**WERKS** (不勾 **PARAM**) ——鎖定範圍是「整個工廠」，不是「單一參數列」，見講義第 3 節的設計理由
4. Lock Mode： **E**
5. 存檔、Activate——系統會產生 **ENQUEUE_EZTR28_WERKS** / **DEQUEUE_EZTR28_WERKS**

第四部分：SM30 Table Maintenance Generator (需使用者手動建立，同練習 21 手法)

1. SE11 該表 → Utilities → Table Maintenance Generator
2. Authorization Group **&NC&**；Function Group **ZFG_TR28**；One step
3. 產生後可以直接用 SM30 手動測試維護畫面本身 (先不管權限/鎖定 Wrapper，純粹確認 View 本身能動)

第五部分：SE93 建立 T-code (需使用者手動建立)

1. SE93 → T-code `ZTR28_MAINT` → Create
2. 型態選 **Program and selection screen (Report transaction)**
3. Program 填 `ZR_TR28_PARAM_MAINT` (**Wrapper** 程式，不是 **SM30**、不是 **View** 名稱)，Screen `1000`
4. 存檔

第六部分：程式 (已由 Claude 建立並啟用，見下方原始碼)

⚠ 這一版設計把「選取畫面按鈕」改成 **SELECTION-SCREEN FUNCTION KEY** (純 ABAP 語法)，不再需要 **SE41 建 GUI Status**——原本規劃的第六部分 (SE41) 已經拿掉，本題的 GUI-only 手動步驟只剩五項 (SU21 / PFCG / SE11 Lock Object / SM30 / SE93)。

- `ZR_TR28_PARAM_MAINT` (Wrapper，走完整保護流程)：選取畫面 `p_werks` (工廠，預設 `1011`) + `p_disp` (勾選 = 只顯示)。依序：**AUTHORITY-CHECK** → (維護模式才) **ENQUEUE_EZTR28_WERKS** → **VIEW_MAINTENANCE_CALL** (帶 `dba_sellist` 篩選 `WERKS = p_werks`，只顯示這個工廠) → (維護模式才) **DEQUEUE_EZTR28_WERKS**
- `ZR_TR28_PARAM_LIST` (清單 + 刻意「沒有保護」的對照按鈕)：**SELECT-OPTIONS s_werks** 篩選顯示 `ZTR28_WPARAM` 內容；選取畫面用 **SELECTION-SCREEN FUNCTION KEY 1** 加一顆「維護主檔(SM30)」按鈕，**AT SELECTION-SCREEN** 判斷 `sscrfields-ucomm = 'FC01'` 時，直接 **SET PARAMETER ID 'VIM' FIELD 'ZTR28_WPARAM'. + CALL TRANSACTION 'SM30' AND SKIP FIRST SCREEN.**——完全不經過 **Wrapper**，沒有權限檢查、沒有 Lock、也沒有工廠篩選，刻意跟 `ZR_TR28_PARAM_MAINT` 做對照 (詳見講義第 7 節的對照表)

測試流程

未建齊 **GUI-only** 物件時 (`programrun` 無頭驗證，已由 Claude 執行過)：

`ZR_TR28_PARAM_LIST` (空表) → 印出「 (沒有資料，或選取條件沒有命中)」
`ZR_TR28_PARAM_MAINT` (`p_werks=1011`) → 權限不足：無法對工廠 `1011` 執行 維護 (`sy-subrc = 12`，官方定義是「User Master Record 裡完全沒有這個物件的任何授權」，不是「物件不存在」——**PFCG** 沒做之前一律會是 `12`)

五項 **GUI-only** 作業 (含 **PFCG** 指派 `ZTR28_WERK` 角色 `ACTVT=02`、`WERKS=1011`) 都做好之後：

1. 直接執行 `ZR_TR28_PARAM_MAINT` (`p_werks=1011`，不勾顯示)：應該看到「權限檢查通過」→「鎖定成功」→跳出 **SM30** 風格的維護畫面，且只看得到 `WERKS=1011` 這一個工廠的資料列 (`dba_sellist` 篩選生效) → 離開畫面後印出「已解鎖工廠」
2. 開兩個 Session，都對 `1011` 執行維護：第二個應該在 **ENQUEUE** 那一步被擋下 (**FOREIGN_LOCK**)
3. `p_disp` 打勾 (顯示模式)：應該能看、但維護畫面裡的變更功能被關閉，且完全不會呼叫 **ENQUEUE** (顯示不用搶鎖)
4. 執行 T-code `ZTR28_MAINT` (不透過 `ZR_TR28_PARAM_LIST`)：應該直接進到跟上面一樣的選取畫面
5. 執行 `ZR_TR28_PARAM_LIST`，選取畫面上按「維護主檔(SM30)」按鈕：應該直接跳進 `ZTR28_WPARAM` 的 **SM30** 維護畫面，這次看得到所有工廠的資料 (沒有篩選)，也不會有權限檢查訊息——跟第 1 步的行為對比，具體感受「有沒有包 Wrapper」的差別

思考題

1. 如果把 **ACTVT** 拿掉，權限物件只剩 **WERKS** 一個欄位，會失去什麼控管能力？（提示：想想「能看但不能改」這種需求還做不做得得到）
2. 為什麼 Wrapper 程式的 **AUTHORITY-CHECK** 跟 **VIEW_MAINTENANCE_CALL** 內部自己的權限檢查不衝突、也不是多餘的？兩者各自把關什麼？
3. 如果 Lock Object 的 Lock Parameters 改成勾整個主鍵（**MANDT+WERKS+PARAM**），會有什麼實際後果？兩個人分別維護同工廠、不同參數代碼的資料時，行為會有什麼不同？
4. **p_disp**（顯示模式）完全不呼叫 **ENQUEUE / DEQUEUE**，這樣設計合理嗎？如果兩個人都用顯示模式同時打開同一個工廠，會有問題嗎？
5. 如果某個使用者的角色同時擁有 **S_TABU_DIS**（對 **&NC&** Authorization Group 有維護權限）跟這支 T-code，但沒有被指派 **ZTR28_WERK** 這個自訂權限物件，這個使用者能不能繞過 Wrapper、直接用 **SM30** 改到 **ZTR28_WPARAM** 的資料？這代表整個防護設計還缺了哪一塊角色/權限管理上的配套？

答案

見 **zr_tr28_param_maint.prog.abap**、**zr_tr28_param_list.prog.abap**（SAP 端 **ZR_TR28_PARAM_MAINT / ZR_TR28_PARAM_LIST**）。DDIC 表 **ZTR28_WPARAM** 快照見 **ztr28_wparam.tab1.abap**。權限物件 **ZTR28_WERK**、PFCG 角色 **ZTR28_MAINT_ROLE**、Lock Object **EZTR28_WERKS**、T-code **ZTR28_MAINT** 均為 GUI-only（**SU21 / PFCG / SE11 / SE93** 皆無 ADT 建立 API），無程式碼快照，需照上方步驟手動建立。

已用 **programrun** 驗證的部分：兩支程式皆已建立、啟用、無語法錯誤；**ZR_TR28_PARAM_MAINT** 在權限物件尚未建立、以及物件已建立但 PFCG 尚未指派兩種情境下，都正確回報「權限不足（**sy-subrc=12**）」，證實 Wrapper 的檢查順序與邏輯正確——**sy-subrc=12** 的官方定義是「**User Master Record** 裡完全沒有這個物件的任何授權」，不是「物件不存在」，這兩種情境剛好都符合這個定義（一種是物件真的不存在、一種是物件存在但沒人被授權），所以看到同樣的 **12** 是正常的，不是 **bug**。等 PFCG 指派完成、且值填對之後，應該轉為 **sy-subrc=0**；如果角色的 **WERKS** 值填錯（例如填了 **1011** 以外的值卻拿 **1011** 來測），會轉成 **sy-subrc=4**（找得到授權但值不對）而不是 **12**——這兩種失敗情境在 **SU53** 交易碼裡也會顯示不同的診斷內容，是排查權限問題時的重要線索。五項 GUI-only 作業建好後的端對端驗證（含 **VIEW_MAINTENANCE_CALL** 畫面互動、雙 **Session FOREIGN_LOCK**、選取畫面按鈕）需要使用者在 **SAP GUI** 手動確認，這部分不受 ADT **programrun** 支援（跟講義提過的「會開全螢幕畫面的呼叫沒辦法無頭驗證」限制相同）。

2026-07-31 補課：新增 VIEW_MAINTENANCE_CALL 的 dba_sellist 工廠篩選 + 改用 SELECTION-SCREEN FUNCTION KEY——原本 **ZR_TR28_PARAM_MAINT** 呼叫 **VIEW_MAINTENANCE_CALL** 沒有篩選條件，通過權限檢查後一樣看得到全部工廠的資料，是設計上的漏洞，已補上 **dba_sellist** 只篩出 **p_werks** 那個工廠；**ZR_TR28_PARAM_LIST** 原本用 **SET PF-STATUS + AT USER-COMMAND**（畫在輸出清單上、且需要額外的 **SE41 GUI Status**），改成選取畫面本身的 **SELECTION-SCREEN FUNCTION KEY**，並刻意讓這顆按鈕不經過 Wrapper、直接 **CALL TRANSACTION 'SM30'**，跟 **ZR_TR28_PARAM_MAINT** 的正規做法做教學對照（見講義第 7 節對照表）。**ZR_TR28_PARAM_LIST** 已重新推送並確認啟用；**ZR_TR28_PARAM_MAINT** 的 **dba_sellist** 修正已寫好但因為物件被鎖定（疑似使用者當時在 **SE38** 開著編輯）尚未成功推送到 **SAP**，下次要先確認物件沒被鎖住，再重新推送 + 驗證。